

Unit 4 Study Guide: Cyber Security Incident Response

1. Cyber Security Incident Response Plan (CSIRP / IRP)

1.1 What it is

A Cyber Security Incident Response Plan is a documented set of instructions designed to help an organisation **prepare for, detect, respond to, and recover from cyber incidents**. It ensures everyone knows their role and the steps to follow, reducing downtime, financial loss, and reputational damage.

1.2 When it is used

The plan is activated whenever a cyber incident occurs, including:

- **Ransomware attacks:** Files encrypted and unusable until a ransom is paid
- **Data breaches:** Theft or unauthorised access to sensitive information
- **Phishing attacks:** Employees' accounts compromised
- **DDoS attacks:** Systems or services disrupted by traffic overload
- **Insider threats:** Employees misusing access for malicious purposes

1.3 Stages of the Cyber Security Incident Response Lifecycle (NIST / PDRR)

1. **Preparation:** Set up the plan, train staff, implement security tools, and run simulations
2. **Detection & Analysis:** Identify incidents, assess scope, determine severity, and investigate root cause
3. **Containment, Eradication & Recovery:** Stop the attack, remove threats, restore systems safely
4. **Post-Incident Activity (Lessons Learned):** Review what happened, update the plan, improve processes

2. Incident Logging and Plan Maintenance

2.1 Why maintain an up-to-date incident log

- Tracks all incidents for analysis and trend identification
- Supports compliance with laws and regulations
- Provides evidence for audits and post-incident review

2.2 Steps to include in a CSIRP

- Identify and classify incidents
- Assign roles and responsibilities
- Outline containment, eradication, and recovery procedures
- Define communication and reporting procedures

- List tools, resources, and access requirements
- Conduct post-incident review

2.3 Importance of having a CSIRP

- Minimises operational disruption and financial loss
- Protects reputation and customer trust
- Ensures compliance with legal and regulatory requirements
- Reduces panic and confusion during a crisis
- Supports better financial decision-making

2.4 Developing a CSIRP

- Customise to organisation-specific systems, workflows, and regulatory requirements
- Assign named personnel and backups for critical roles
- Include clear procedures for different incident types
- Integrate existing IT infrastructure and security tools
- Provide staff training and regular drills to test readiness

3. Incident Post-Mortem

3.1 What it is

A post-mortem is a **structured, blameless review** conducted after a cyber incident to:

- Understand what happened
- Identify why it happened
- Evaluate the response
- Extract lessons to prevent future incidents

3.2 Structure

1. **Introduction & Ground Rules:** Blameless, constructive discussion
2. **Incident Summary:** High-level overview of impact and timeline
3. **Timeline Reconstruction:** Step-by-step account of events
4. **Root Cause Analysis (RCA):** Identify direct and contributing causes
5. **Response Analysis:** Evaluate what went well and what failed
6. **Lessons Learned & Recommendations:** Actionable improvements

3.3 Importance of Intensity, Integrity, Rigour, and Discipline

Principle	Explanation
Intensity	Analyse the incident thoroughly, challenge assumptions
Integrity	Honest, blameless process to reveal true causes
Rigour	Use evidence-based analysis, avoid assumptions
Discipline	Follow process consistently, document and track actions

3.4 Creating a Post-Mortem Report

- Title, date, and participants
- Executive summary of the incident
- Detailed timeline of events
- Root cause analysis and contributing factors
- Impact assessment (operational, financial, reputational)
- Lessons learned and SMART recommendations

3.5 Reflection and Recommendations

- Ensure recommendations are **practical, achievable, and supported by management**
- Address root causes and system weaknesses
- Prioritise based on risk, cost, and resources
- Update CSIRP, policies, and training based on lessons learned

Case Study Reference

- Real-life incidents (e.g., British Airways Magecart, KNP Logistics ransomware) illustrate the importance of:
 - Preparing before incidents occur
 - Customising plans for organisation-specific risks
 - Conducting thorough post-mortems to improve future resilience